

The NIST Cybersecurity Framework (also known as NIST CSF), is a set of guidelines designed to help organizations assess and improve their preparedness against cybersecurity threats. Developed in 2014 by the U.S. National Institute of Standards and Technology, the framework has since been applied in areas including industrial data security and quantum-security risk assessment. The NIST framework has provided a basis for communication and understanding of cybersecurity principles between organizations, both in the private sector and public, such as governments. The framework, which is publicly available online for free, provides recommendations of existing cybersecurity standards and actions that organizations can take to mitigate cybersecurity risk.

The NIST CSF is made up of three overarching components: the CSF Core, CSF Organizational Profiles, and CSF Tiers. The CSF Core is divided into six functions, each focused on maximizing cybersecurity preparedness, improving communication, and mitigating risk. The six CSF Core functions include: Govern, Identify, Protect, Detect, Respond, and Recover. These six core functions are then further broken down into subcategories. The CSF Organizational Profiles provide guidance on how organizations can assess themselves in terms of the CSF Core and where their cybersecurity practices can be improved and implemented. The CSF Tiers characterize and evaluate an organization's cybersecurity readiness and ability to mitigate risks. The CSF Tiers are helpful for organizations to know what level of cybersecurity protection they have in place and the processes behind the protection.

After its publishment in 2014, the NIST CSF has been updated to reflect the most current cybersecurity practices. Among these updates is version 1.1, which was released in 2018. In version 1.1, changes were made to the framework to include supply chain risk management and new self-assessment processes. The current version of the NIST CSF is version 2.0, which was released in 2024. This current version introduced a new function to the CSF Core: Govern. Version 2.0 also increased the scope of the NIST CSF framework and its applicability to smaller organizations. Improvements to the framework language were also made, increasing its

readability for non-technical audiences.

The NIST Cybersecurity Framework is used internationally by organizations of varying sizes and sectors. Available for free to implement, NIST CSF sets cybersecurity guidelines and best practices for organizations to increase their defense against cyber threats and prepare for future risks.

Overview

The NIST Cybersecurity Framework (CSF) is a set of guidelines developed by the U.S. National Institute of Standards and Technology (NIST) to help organizations manage and mitigate cybersecurity risks. It draws from existing standards, guidelines, and best practices to provide a flexible and scalable approach to cybersecurity. The framework provides a high-level taxonomy of cybersecurity outcomes and offers a methodology for assessing and managing those outcomes. Additionally, it addresses the protection of privacy and civil liberties in a cybersecurity context.

The CSF has been translated into multiple languages and is widely used by governments, businesses, and organizations across various sectors. According to a 2016 survey, 70% of organizations view the NIST Cybersecurity Framework as a best practice for computer security, though some have noted that implementation can require significant investment.

The framework is designed to be flexible and adaptable, providing high-level guidance that allows individual organizations to determine the specifics of implementation based on their unique needs and risk profiles.

Version 1.0 of the framework was published in 2014, primarily targeting operators of critical infrastructure. A public draft of Version 1.1 was released for comment in 2017, and the final version was published on April 16, 2018. Version 1.1 retained compatibility with the original framework while introducing additional guidance on areas such as supply chain risk management. Version 2.0 was released in 2024 and is the most current version of the NIST

framework. This new version made significant updates to Version 1.1, by adding a "Govern" function to the CSF Core, expanding the framework's scope and applicability, and improving readability for non-technical stakeholders.

The NIST Framework is made up of three main components: the CSF Core, CSF Organization Profiles, and CSF Tiers. The Core consists of six distinct functions, each contributing to a specific area of cybersecurity and risk management. These six functions are broken down into categories and subcategories. The Organization Profiles help organizations assess their current state of cybersecurity preparedness in terms of the CSF Core, and where improvements and adjustments can be made. The CSF Tiers help inform organizations on their current and target profiles in the CSF Organization Profiles. The CSF Tiers determine how rigorous an organization's current cybersecurity risk governance practices are and help to provide context for an organization's cybersecurity strategies and processes that are in place. Organizations typically start by developing a "Current Profile" to describe their existing cybersecurity practices and outcomes. From there, they can create a "Target Profile" to outline the desired future state and define the steps needed to achieve it. Alternatively, organizations can adopt a baseline profile based on their sector or specific industry needs.

Research indicates that the NIST Cybersecurity Framework has the potential to influence cybersecurity standards both within the United States and internationally, particularly in sectors where formal cybersecurity standards are still emerging. This influence could foster better international cybersecurity practices, benefiting businesses that operate across borders and contributing to global cybersecurity efforts. In the healthcare sector, NIST has published Special Publication 800-66 Revision 2, which provides a detailed crosswalk mapping the HIPAA Security Rule requirements to the NIST CSF, enabling covered entities and business associates to use the framework for HIPAA compliance.

NIST CSF Core Functions

The Core is one of the three overarching components of the NIST CSF. The Core is categorized into six functions, which are further divided into 22 categories. Each category is then further divided, amounting to a total of 106 subcategories of cybersecurity outcomes.

For each subcategory, it also provides "Informative Resources" referencing specific sections of a variety of other information security standards, including ISO 27001, COBIT, NIST SP 800-53, ANSI/ISA-62443, and the Council on CyberSecurity Critical Security Controls (CCS CSC, now managed by the Center for Internet Security). Special Publications (SP) aside, most of the informative references requires a paid membership or purchase to access their respective guides. The cost and complexity of the framework has resulted in bills from both houses of Congress that direct NIST to create Cybersecurity Framework guides that are more accessible to small and medium businesses.

Here are the functions and categories, along with their unique identifiers and definitions, as stated in the framework document.

Govern

According to NIST CSF 2.0, the Govern function is defined as: "the organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored."

The Govern function is divided into six categories. These six categories are defined below according to NIST CSF 2.0:

Organizational Context (GV.OC): "The circumstances — mission, stakeholder expectations, dependencies, and legal, regulatory, and contractual requirements — surrounding the organization's cybersecurity risk management decisions are understood."

Risk Management Strategy (GV.RM): "The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated, and used to

support operational risk decisions"

Roles, Responsibilities, and Authorities (GV.RR): "Cybersecurity roles, responsibilities, and authorities to foster accountability, performance assessment, and continuous improvement are established and communicated"

Policy (GV.PO): "Organizational cybersecurity policy is established, communicated, and enforced"

Oversight (GV.OV): "Results of organization-wide cybersecurity risk management activities and performance are used to inform, improve, and adjust the risk management strategy"

Cybersecurity Supply Chain Risk Management (GV.SC): "Cyber supply chain risk management processes are identified, established, managed, monitored, and improved by organizational stakeholders"

Identify

"Develop the organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities."

Asset Management (ID.AM): The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to business objectives and the organization's risk strategy.

Business Environment (ID.BE): The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.

Governance (ID.GV):- The policies, procedures, and processes to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.

Risk Assessment (ID.RA): The organization understands the cybersecurity risk to organizational

operations (including mission, functions, image, or reputation), organizational assets, and individuals.

Risk Management Strategy (ID.RM): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.

Supply Chain Risk Management (ID.SC): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing supply chain risk. The organization has in place the processes to identify, assess and manage supply chain risks.

Protect

"Develop and implement the appropriate safeguards to ensure delivery of critical infrastructure services."

Access Control (PR.AC): Access to assets and associated facilities is limited to authorized users, processes, or devices, and to authorized activities and transactions.

Awareness and Training (PR.AT): The organization's personnel and partners are provided cybersecurity awareness education and are adequately trained to perform their information security-related duties and responsibilities consistent with related policies, procedures, and agreements.

Data Security (PR.DS): Information and records (data) are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.

Information Protection Processes and Procedures (PR.IP): Security policies (that address purpose, scope, roles, responsibilities, management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage protection of information systems and assets.

Maintenance (PR.MA): Maintenance and repairs of industrial control and information system components is performed consistent with policies and procedures.

Protective Technology (PR.PT): Technical security solutions are managed to ensure the security and resilience of systems and assets, consistent with related policies, procedures, and agreements.

Detect

"Develop and implement the appropriate activities to identify the occurrence of a cybersecurity event."

Anomalies and Events (DE.AE): Anomalous activity is detected in a timely manner and the potential impact of events is understood.

Security Continuous Monitoring (DE.CM): The information system and assets are monitored at discrete intervals to identify cybersecurity events and verify the effectiveness of protective measures.

Detection Processes (DE.DP): Detection processes and procedures are maintained and tested to ensure timely and adequate awareness of anomalous events.

Respond

"Develop and implement the appropriate activities to take action regarding a detected cybersecurity incident."

Response Planning (RS.RP): Response processes and procedures are executed and maintained, to ensure timely response to detected cybersecurity events.

Communications (RS.CO): Response activities are coordinated with internal and external stakeholders, as appropriate, to include external support from law enforcement agencies.

Analysis (RS.AN): Analysis is conducted to ensure adequate response and support recovery activities.

Mitigation (RS.MI): Activities are performed to prevent expansion of an event, mitigate its effects, and eradicate the incident.

Improvements (RS.IM): Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities.

Recover

"Develop and implement the appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident."

Recovery Planning (RC.RP): Recovery processes and procedures are executed and maintained to ensure timely restoration of systems or assets affected by cybersecurity events.

Improvements (RC.IM): Recovery planning and processes are improved by incorporating lessons learned into future activities.

Communications (RC.CO): Restoration activities are coordinated with internal and external parties, such as coordinating centers, Internet Service Providers, owners of attacking systems, victims, other CSIRTs, and vendors.

NIST CSF Organizational Profiles

Organizational Profiles are also part of the three overarching components of the NIST CSF. The Organizational Profiles provide guidance to organizations on how they can assess themselves in terms of the CSF Core and where they can improve and implement their cybersecurity practices according to their mission objectives, stakeholder expectations, the threat landscape, and other needs. This way, organizations can focus on specific areas of cybersecurity to meet their goals and communicate these changes to stakeholders.

An Organizational Profile can be one or both of the following:

A Current Profile: describes the Core outcomes that an organization is meeting or aiming for and informs organizations on how they are achieving each outcome.

A Target Profile: describes the goals for cybersecurity risk management that an organization has selected to pursue. A Target Profile takes into account incoming changes to an organization's cybersecurity practices including new requirements, technology integration, and trends of threat intelligence.

Additionally, an organization can follow a Community Profile:

A Community Profile is a set of CSF outcomes that a group of organizations has selected to pursue to reach shared cybersecurity goals and interests. Community Profiles are commonly created for different sectors, technologies, threats, and other specific areas. Additionally, organizations can set a Community Profile as their Target Profile, creating an outline of improvements they can work towards together to improve their cybersecurity risk management.

Below are one-way organizations can use an Organizational Profile to improve their cybersecurity practices, as described by NIST CSF 2.0:

"Scope the Organizational Profile.": An organization needs to decide the scope, or how broad they want their Organizational Profile to be. An organization can have multiple Organizational Profiles, ranging from a single Profile for the entire organization or different ones for specific areas such as fighting cyber-attacks.

"Gather the information needed to prepare the Organizational Profile.": Organizations need to collect information before creating their Profile. Information can consist of organizational policies and rules, priorities for managing risk and resources, cybersecurity requirements, and other practices followed by an organization.

"Create the Organizational Profile.": This step involves deciding what information the Profile will have based on the chosen CSF outcomes. This includes understanding the risks of the Current Profile and determining what improvements should be made to it to then create the Target Profile. An organization can use a Community Profile as their Target Profile.

"Analyze the gaps between the Current and Target Profiles, and create an action plan.": After creating an Organizational Profile, organizations should analyze how their Current Profile and Target Profile differ and create a plan to achieve their Target Profile.

"Implement the action plan, and update the Organizational Profile.": The final step is to act and follow the plan made in the previous step to achieve the Target Profile. The Target Profile can have a deadline that the organization has selected or remain an ongoing process.

These steps can be repeated as many times as the organization desires to continuously improve their cybersecurity risk preparedness.

NIST CSF Tiers

The CSF Tiers characterize and evaluate an organization's cybersecurity readiness and ability to mitigate risks. The CSF Tiers are helpful for organizations to be informed of what level of cybersecurity protection they currently have and the processes behind the protection. The Tiers can be used to inform an organization's Current and Target Profiles. There are four Tiers which describe an organization's cybersecurity risk preparedness. The four Tiers include: Partial (Tier 1), Risk Informed (Tier 2), Repeatable (Tier 3), and Adaptive (Tier 4). The Tiers provide guidance on how organizations can improve their cybersecurity practices by describing increasing levels of cybersecurity risk management. The Tiers can also be used to inform all people in an organization of the chosen level of cybersecurity practices, so employees are aware of the organization's security goals. Although the Tiers provide organizations with an overall evaluation of their cybersecurity preparedness, the Tiers should be used as a complement and not replace the Organizational Profiles.

Updates

In 2021 NIST released Security Measures for "EO-Critical Software" Use Under Executive Order (EO) 14028 to outline security measures intended to better protect the use of deployed EO-critical software in agencies' operational environments.

Journey to CSF 2.0

The NIST Cybersecurity Framework is meant to be a living document, meaning it will be updated and improved over time to keep up with changes in technology and cybersecurity threats, as well as to integrate best-practices and lessons learned. Since releasing version 1.1 in 2018, stakeholders have provided feedback that the CSF needed to be updated. In February 2022, NIST released a request for information on ways to improve the CSF, and released a subsequent concept paper in January 2023 with proposed changes. Most recently, NIST released its Discussion Draft: The NIST Cybersecurity Framework 2.0 Core with Implementation Examples and has requested public comments be submitted by November 4, 2023.

Main Changes

The following is a list of the major changes to the framework from version 1.1 to 2.0:

The title of the framework has changed from "Framework for Improving Critical Infrastructure Cybersecurity" to "Cybersecurity Framework". The scope of the framework has been updated to reflect the large population of organizations that use the framework.

Implementation examples have been added to provide practical and action-oriented processes to help users achieve the CSF subcategories. Additionally, the framework Profiles have been revised and expanded to demonstrate the various purposes of the profiles.

A new Function, Govern, has been added to provide organizational context and the roles and responsibilities associated with developing a cybersecurity governance model. There is also an additional category in this Function focused on cybersecurity supply chain risk management. The latest update also provides greater information on cybersecurity assessments by placing greater importance on the continuous improvement of security through a new Improvement Category in the Identify Function.

See also

Cybersecurity

Cyber security standards

Privacy

Critical infrastructure protection

ISO/IEC 27001:2013: an information security standard from the International Organization for Standardization

COBIT: Control Objectives for Information and Related Technologies - a related framework from ISACA

NIST Special Publication 800-53: "Security and Privacy Controls for Federal Information Systems and Organizations."

Risk Management Framework - US-federally mandated risk framework (broader scope than cybersecurity)

References

This article incorporates public domain material from NIST Cybersecurity Framework (PDF). National Institute of Standards and Technology.

External links

[Official website](#)

[Harnessing the Power of the NIST Cybersecurity Framework](#)

[NISTIR 8374 \(Draft\): Cybersecurity Framework Profile for Ransomware Risk Management
\(Preliminary Draft\)](#)

[Informative References Home](#)

[Derived Relationship Mapping](#)

[Informative Reference Catalog](#)